

RIPPOTAI ERP (INOS)

Backend Software Architecture Review

System architecture, domain model, security posture, quality assessment and technical roadmap

Item	Detail
Document	Backend architecture review and technical documentation
Version	1.0 (review draft for engineering leadership)
Date	10 October 2026
Source reviewed	backend.zip (backend/ source tree, db.sql schema dump, documentation/ folder)
Perspective	Software architecture
Classification	Internal. Contains security findings; restrict distribution.

Document control

Version	Date	Author	Change
0.1	10 Oct 2026	Architecture review	Initial static review of backend.zip, build and test verification.
1.0	10 Oct 2026	Architecture review	Full documentation, findings register and roadmap.

How to read this document

Sections 1 to 3 are for leaders deciding priorities. Sections 4 to 15 describe the architecture for engineers joining or reviewing the system. Section 16 is the findings register, the authoritative list of issues, each with file evidence. Sections 17 to 19 cover decisions, the roadmap and day-to-day developer guidance. Appendices provide the complete controller inventory, environment variables, schema table groups and the verification log.

Verification basis. Findings come from reading the source, running the production build, the type checker and the unit test suite, and from static analysis of routes and queries. No live HTTP requests were made and no database was connected, so runtime behaviour of the security findings must be confirmed in staging before remediation is scoped. Each finding names its evidence so it can be checked independently.

Contents

- 1 Executive summary
 - 2 Scope, sources and method
 - 3 System context
 - 4 Technology platform
 - 5 Architectural style and module decomposition
 - 6 Runtime architecture
 - 7 Domain model
 - 8 Key runtime flows
 - 9 Security architecture
 - 10 Data architecture
 - 11 Integration architecture
 - 12 Background processing and real-time
 - 13 Deployment and operations
 - 14 Quality engineering
 - 15 Non-functional assessment
 - 16 Findings register
 - 17 Architecture decisions (as found)
 - 18 Remediation roadmap
 - 19 Developer operating guide
 - 20 Assumptions, limitations and glossary
- Appendix A Controller and route inventory
- Appendix B Environment variables
- Appendix C Schema table groups
- Appendix D Verification log

1 Executive summary

Rippotai ERP is a single NestJS 11 service backed by MySQL, with Redis, Elasticsearch, Socket.IO and headless Chromium. It runs the operating workflow of an architecture practice end to end: lead capture and CRM sync, project briefs and site reconnaissance, scope and BOQ preparation with approval, vendor shortlisting and procurement, budgeting and payment milestones, a document and drawing register, site operations, planning, a twelve-gate project progression engine, automation rules, and a public client portal for approvals and handover.

At code level the system is more mature than its size suggests. It has a consistent module layout, validated DTOs, server-side session revocation, transactional gate control with row locks, a well-reasoned caching layer, and a build that passes cleanly. The weaknesses are concentrated in a small number of cross-cutting areas, and they are serious enough that the platform should not be exposed to untrusted users until the first remediation phase is complete.

Headline assessment

Dimension	Rating	Basis
Authentication	Adequate	JWT with DB-backed revocation and bcrypt. Undermined by open signup and an unguarded auth administration surface.
Authorization	Critical gap	RBAC permission model exists, but enforcement is applied to one controller only. Authentication is effectively the only check.
Security hygiene	Weak	No rate limiting, no security headers, public system information, permissive origins, weak key derivation.
Data integrity	Mixed	Transactional locking in gates and version counters are good. Approvals can lack an actor. Search index is not kept current.
Scalability	Limited	Single process, in-process timers with no distributed lock, pool of 5, PDF rendering inside the API.
Reliability	Limited	Readiness is static. No durable queue or outbox. Events are lost on restart.
Maintainability	Moderate	Consistent structure and extensive domain modelling. Large services, heavy use of any, mixed ID schemes and drifted docs.
Testability	Weak	Default test command loads 3 of 32 suites. With a workaround, 232 of 234 tests pass.
Operability	Weak	Minimal metrics and tracing, unvalidated configuration, root container.

The five things to do first

1. Confirm, in staging, that routes listed in Section 16 respond without a token. Then review audit and approval history for changes made while those routes were open, and treat any unexplained change as a potential security incident.

2. Add a default-deny global guard with an explicit public allow-list, and a CI test that fails on any unclassified route (SEC-01).
3. Disable or gate open self-registration. Require verification before a session is issued, and apply the existing PortalAccessGuard and permission checks (SEC-02).
4. Guard the search reindex, auth token administration, Zoho CRM proxy and BOQ approval routes, and reject null actors on approvals (SEC-03 to SEC-06).
5. Repair the unit test command so that a green build means something (QA-01 and QA-02).

Scale of the exposure. Of 954 route handlers, 576 (60%) have no framework-level authentication. This is the single largest risk in the platform and should be treated as a release blocker.

2 Scope, sources and method

2.1 In scope

The NestJS backend in backend/, including its Docker and Compose configuration, migrations, seed tooling, tests, the schema dump db.sql, and the design documents in backend/docs and backend/migrations. The documentation/ folder that sits alongside the backend was read to confirm or contradict the code; where it disagrees with the code, the code is treated as authoritative and the disagreement is recorded as a finding.

2.2 Out of scope

- The React frontend (referenced only where it affects backend behaviour, such as token storage and CORS).
- Production infrastructure outside the repository: reverse proxy, TLS termination, firewalls, database grants, backups and disaster recovery.
- Load and performance measurement, penetration testing and live data validation.

2.3 Method

6. Structural survey: directory tree, module inventory, controller and route inventory generated from source.
7. Configuration review: app bootstrap, module wiring, database configuration, Docker and Compose files, CI references.
8. Security review: guard coverage per route, authentication and token lifecycle, authorization paths, CORS, file handling, public endpoints.
9. Data review: schema dump, model definitions, transaction usage, locking, raw SQL call sites, migration practice.
10. Verification: clean install, production build, type check, unit test suite (default and with path mapping), and a reading of the design documents against the implementation.

Reproducibility. Every count in this document is reproducible from the archive with the commands recorded in Appendix D.

3 System context

The ERP serves an architecture practice that runs multi-project engagements. Its users are internal staff with role-based access (administrators, architects, site engineers, procurement and finance staff), external vendors who receive quotation and enquiry links, and clients who review and approve BOQs and handover packages through tokenised public links. The ERP integrates with the practice's CRM and collaboration tools and sends transactional email.

3.1 Actors and external systems

Actor or system	Relationship	Interface
Internal staff	Primary users of all modules	Staff SPA over HTTPS with Bearer JWT, plus Socket.IO for notifications
Administrators	Manage users, roles, settings, automation and search	Same SPA, admin-only routes (enforced in the frontend only, see SEC-02)
Clients	Review BOQs and quotations, approve, accept handover	Public tokenised routes under /public/client/:token
Vendors	Receive enquiries and submit quotations	Vendor-facing links and the quotation module
Zoho (Begin, Projects, Cliq, WorkDrive, Calendar)	CRM sync, project task sync, file storage, calendar	OAuth 2 with stored refresh tokens; REST
Google and Microsoft	Calendar, Tasks, OneDrive	OAuth 2 with stored tokens
Brevo	Transactional email (verification, password reset, notifications)	Brevo SDK
SFTP CDN or local disk	Document and image storage	ssh2-sftp-client, or static /cdn directory
MySQL	System of record	Sequelize over mysql2
Redis	Socket.IO adapter, command-centre cache, gate locks	ioredis
Elasticsearch	Global and entity search	@elastic/elasticsearch

3.2 Business capabilities

Capability	Principal modules
Client and lead management	clients, leads, reki (site recces), brief, sync
Project delivery	projects, gates, process-workflow, plan-of-action, tasks, calendar, scope-of-work
Commercial	boqs, quotations, budget-estimate, payments, business-proposals, vendor-rate-comparisons

Capability	Principal modules
Procurement and vendors	material-procurement, vendors, inventory, work-orders, purchase orders, delivery challans
Documents and drawings	documents, drawings, document requirements, admin DPR documents
Site operations and quality	site-operations (visits, daily reports, QC, snags, RFIs, mock-ups)
Control and oversight	automation, engagement (notifications, activity), dashboard, reports, search
Administration	auth, users, team, rbac, apps, settings, metas, cdn

4 Technology platform

Layer	Technology (from package.json and Dockerfile)	Comment
Runtime	Node.js 20 (node:20-alpine image); TypeScript 5.7	Image includes Chromium for PDF rendering
Framework	NestJS 11 (core, common, platform-express, platform-socket.io, websockets, swagger, config, passport, jwt)	Global prefix api/v1
ORM and database	Sequelize 6 with sequelize-typescript; mysql2 driver; MySQL	synchronize disabled; schema via SQL migrations
Authentication	passport-jwt, jsonwebtoken, bcrypt (cost 10)	7-day session tokens with DB revocation
Real-time	Socket.IO 4 with @socket.io/redis-adapter	Redis adapter enabled outside development
Cache and locks	ioredis 5	Command-centre cache, gate-engine coordination
Search	@elastic/elasticsearch 8; 16 entity indices	Manual population only (ARCH-03)
PDF and documents	puppeteer 25 (headless Chromium), pdfkit, exceljs, xlsx	Rendering runs in the API process (ARCH-05)
Files	multer (memoryStorage in several endpoints), ssh2-sftp-client, uuid	Filenames are UUIDv4
Email	@getbrevo/brevo	Transactional
Validation	class-validator, class-transformer, global ValidationPipe (whitelist, transform)	Unknown properties stripped silently
Testing	Jest 30, ts-jest, supertest; scaffold e2e in test/	See Section 14
Packaging and deploy	Docker, docker-compose (api + redis), GitHub Actions to GHCR and VPS over SSH	See Section 13

Observation. Puppeteer, Chromium, Elasticsearch, Redis and MySQL are all required at boot for many features. Degraded modes (for example, Redis unavailable) are handled in the cache layer by falling back to the database, which is good practice, but not uniformly across modules.

5 Architectural style and module decomposition

5.1 Style

The backend is a modular monolith. A single AppModule imports 37 feature modules. Each module follows the same shape: a *.module.ts wiring one or more controllers and services, Sequelize models under models/, and request DTOs under dto/. The layering is conventional for NestJS: controllers handle HTTP concerns and DTO validation, services hold domain logic and transactions, and models define persistence. Cross-cutting concerns live in src/common (guards, decorators, interceptors, the Redis module, the mail service, and the in-process automation bus).

The codebase contains no forwardRef usage, which indicates module dependencies have been kept acyclic. This is a real strength and keeps the option open to extract modules later.

5.2 Module inventory

Lines of TypeScript and controller count per module, as measured from the source. Controllers are listed in Appendix A.

Module	Lines	Controllers	Responsibility
material-procurement	12,764	12	Requirements, rate sheets, quotations, POs, work orders, challans, inventory
projects	10,048	7	Project directory, phases, planner, command center, dashboards
site-operations	8,867	13	Visits, daily site reports, QC checklists, snags, RFIs, mock-ups, DPR
boqs	5,497	4	BOQs, versions, approvals, templates, library, export
zoho	5,290	5	Zoho Bigin CRM, Projects, Cliq, WorkDrive, Calendar integrations
documents	4,962	6	Document catalogue, versions, drawings and revisions, requirements
vendors	4,213	7	Vendor directory, shortlists, shortlist packages, rate comparisons
engagement	4,181	2	Activity logs and notifications, Socket.IO fan-out
search	3,938	1	Elasticsearch global, entity and autocomplete search
users	3,910	3	Users, teams, signatures, avatars
quotations	2,835	3	Quotations, items, versions, comparison
brief	2,717	1	Project briefs and their child tables
gates	2,676	2	Gate engine: conditions, evidence, transitions, overrides
budget-estimate	2,617	1	Budget estimates and versions
leads	2,470	1	Leads, notes, tasks, activity (Zoho-linked)

Module	Lines	Controllers	Responsibility
auth	2,305	6	Login, signup, sessions, OAuth (Google, Microsoft, Zoho), verification tokens
reki	2,197	1	Site reconnaissance (site recces), rooms and photos
scope-of-work	1,957	1	Scope of work, spaces and items
process-workflow	1,764	5	Process library, progress, timeline, continuity, gates controller
sync	1,735	1	Zoho reminder sync and sync logs
payments	1,284	1	Payment schedules and milestones
automation	1,223	1	Automation rules, engine, triggers, audit
rbac	1,219	5	Roles, permissions, role-app and role-permission mappings
plan-of-action	1,213	1	Plans of action and phases
dashboard	1,145	1	Dashboard widgets and layouts
google	1,032	2	Google Calendar and Tasks
microsoft	1,024	1	Microsoft OneDrive and calendar
tasks	939	1	Tasks and task definitions
metas	789	2	Units and terms-and-conditions templates
client-portal	772	1	Client links (public token), BOQ approval by client, handover
calendar	563	1	Calendar events
workspace	542	2	Workspace notes and tasks
reports	313	1	Read-only aggregate reports
clients	312	1	Client directory
settings	216	1	Application and company settings
cdn	204	1	File upload to SFTP CDN or local static directory
business-proposals	192	1	Business proposals

Table 5.1. Module inventory. Line counts include spec files excluded from the production build.

5.3 Observations on decomposition

- **Domain concentration.** Procurement (about 12.8k lines), projects (about 10k), site operations (about 8.9k) and BOQs (about 5.5k) hold most of the logic. Their service classes are large (Section 16, QA-04).
- **Overlapping concerns.** Process-workflow, projects (phases, planner, command centre) and gates each own a piece of project progression. The gate engine is the authoritative source for clearance,

while the project record holds display caches. The GATE_ENGINE document says so explicitly, which is correct, but a new engineer could easily write to the wrong place.

- **Duplicated pattern.** Several entity families (quotations, material quotations, vendor quotations, budget estimates, BOQs) repeat the same versioning, activity and search patterns. A shared versioning and activity abstraction would reduce drift.
- **Overlapping route ownership.** The `documents` routes exist in two controllers (document.controller.ts and document-register.controller.ts), and `quotations` is served by two controllers under the same prefix. Route ownership should be unambiguous.

6 Runtime architecture

The diagram below shows the logical runtime as deployed by the repository's Compose file. A reverse proxy and TLS termination are not in the repository and are assumed to sit in front of port 5000 in production.

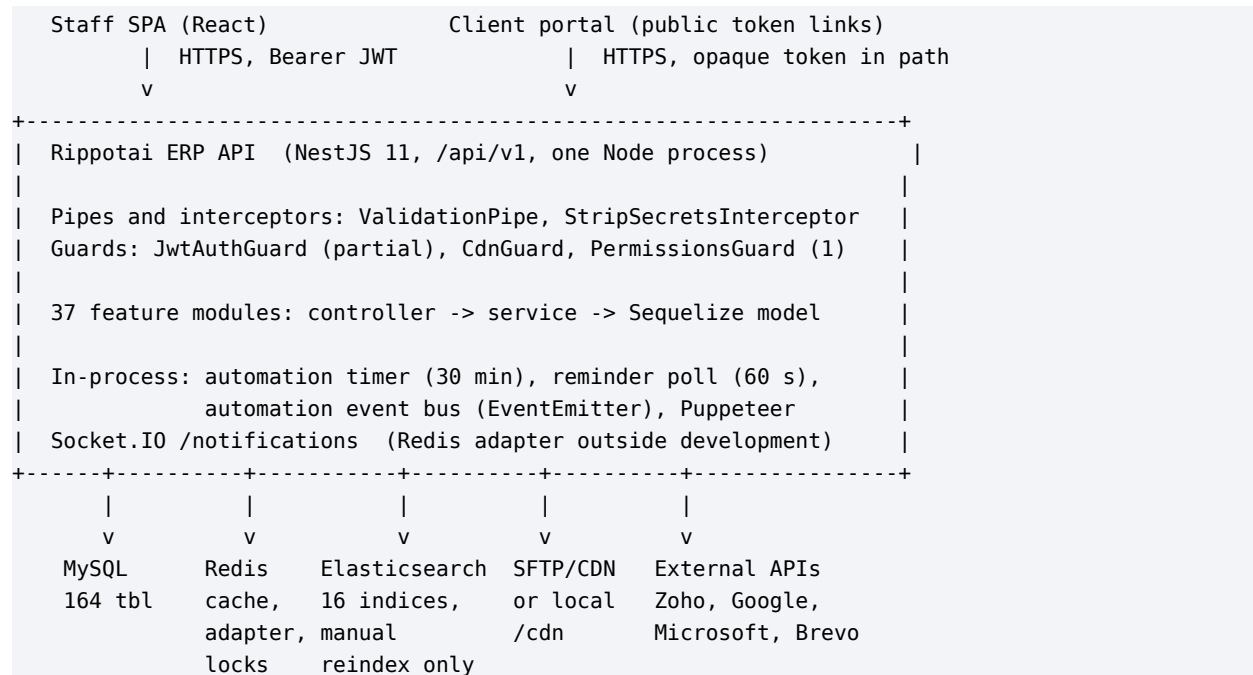


Figure 6.1. Logical runtime architecture (text rendering; boxes are not to scale).

6.1 Request lifecycle

11. The request reaches Express. Body parsing enforces a 3 MB JSON limit, which is set to accommodate saved comparison snapshots.
12. Global ValidationPipe whitelists and transforms the body against the DTO. Unknown properties are dropped silently.
13. If the controller declares JwtAuthGuard, the passport-jwt strategy verifies the signature and expiry, then looks up the token hash in auth_tokens so that revoked sessions fail.
14. If the handler is decorated with @RequirePermission and PermissionsGuard is applied, the user's permissions are checked. This happens only in the gates module today (SEC-02).
15. The service executes business logic, often inside a Sequelize transaction.
16. The response passes through StripSecretsInterceptor, which removes password hashes, token hashes and OAuth tokens at any depth.

6.2 Deployment unit

One Docker image is produced from the repository and runs node dist/src/main.js. The image size is driven by Chromium. The service listens on port 5000, mapped to 5002 on the host in the repository's Compose file. The image contains no non-root user and no health check (OPS-02).

7 Domain model

The schema dump contains 164 tables, and the Sequelize layer maps 162 of them to models. Most business tables use UUID primary keys and carry `created_at`, `updated_at` and, for 41 models, soft-delete via paranoid mode. Appendix C lists the tables by group.

7.1 Core aggregates

Aggregate	Root	Key children and relationships	Lifecycle and invariants
Project	projects	project_phases, project_gates, project_locations, scope categories, planner, shortlists, payment schedules	Phase and progress are display caches; the gate engine decides clearance. Project lock serialises clear and reopen.
Gate	project_gates	gate_definitions (12 in migration), gate_conditions, gate_logs, gate_transition_logs	Clear and reopen run in a transaction with UPDATE row locks and write history atomically. Overrides require <code>allows_override</code> and a reason. Seeded gates prohibit overrides.
Client brief	project_briefs	11 child tables for phases, work types, spaces, services, references, restrictions, documents, attachments	Brief approval and status transitions in <code>brief.service.ts</code> ; approval spec tests exist.
Site recce	site_recces	site_recce_rooms, site_recce_photos	Synced to the search index only by manual reindex.
BOQ	boqs	boq_categories, boq_items, boq_miscellaneous, boq_versions, boq_activities	Versioned. Submit, approve and duplicate-version actions. Approval actor must be recorded (SEC-03).
Quotation	quotations	quotation_items, quotation_versions, quotation_comparisons	Versioned; comparisons select a winner (L1 logic in vendor rate comparisons).
Vendor rate comparison	vendor_rate_comparisons	JSON snapshot of BOQ categories, quantities, vendor identities, rates and totals	Revision counter prevents lost updates. Source BOQ changes do not alter saved sheets, by design.
Procurement	material_requirements	material_procurements, material_quotations, purchase_orders, work_orders, delivery_challans, inventory_transactions	Flow from requirement to order to delivery to stock movement.
Document	documents	document_versions, document_attachments, document_requirements, document_types (83-item catalogue)	Latest submission by creation time and id decides gate evidence. Drawings have separate revisions.

Aggregate	Root	Key children and relationships	Lifecycle and invariants
Drawing	drawings	drawing_revisions	Non-superseded sheets must pass review for gate evidence.
Site visit and DPR	architect_site_visits	architect_visit_stages, visit_assignments, site_visit_logs, daily_site_reports, manpower_entries	Visit assignments are allocated per event.
Quality and snag	quality_checklists	quality_checklist_items, qc_sign_offs, qc_sign_off_item_results, snag_lists, snag_items	QC failures emit QC_FAILED automation events.
RFI and mock-up	rfis, mockups	Status workflows	RFI_OVERDUE automation trigger.
Payment	payment_schedules	payment_schedule_milestones	PAYMENT_MILESTONE_OVERDUE automation trigger; gate payment codes TOKEN and PHASE_01 must match.
Client link	client_links	Token hash, AES-256-GCM encrypted copy, purpose, target, expiry, revocation	Public access is through the token only (Section 9).
Identity	users	roles, teams, team_members, team_sections, auth_tokens, password_reset_tokens, user_signatures	is_active flag exists. Default role USER is assigned on signup.

7.2 Phase vocabularies

The platform uses three phase vocabularies: DOCUMENTS phases (used by the gate engine), consultancy and PMC phases (used by the planner), and process-workflow phases with steps (used by site operations). GATE_ENGINE.md states that Command Center uses the DOCUMENTS vocabulary independently of the planner. Engineers must check which vocabulary a feature uses before reading a phase identifier.

7.3 Data governance observations

- Soft delete is widely used (41 paranoid models), but the search index does not reliably filter deleted records because it is not synchronised (ARCH-03).
- Some tables are keyed by integer identifiers for historical reasons, which complicates joins and any future sharding (ARCH-06).
- Audit is provided by activity_logs and by per-aggregate history tables (gate_transition_logs, boq_activities). Coverage is inconsistent across modules, and audit rows are not protected from modification by the application role.

8 Key runtime flows

8.1 Login and session

17. POST /auth/login verifies the email and bcrypt hash, then creates a random identifier (jti). Only the SHA-256 hash of the identifier is stored in auth_tokens.
18. A JWT is signed with JWT_SECRET, carries jti and expires in 7 days, and is returned to the client.
19. On each guarded request, passport-jwt verifies the signature and expiry, then recomputes the hash of jti and looks up a live auth_tokens row. Revoked or expired rows fail.
20. Logout and revoke-all mark rows as revoked. Because revocation is in the database, it takes effect on the next request.

This design is sound. Its weaknesses are operational rather than conceptual: signup issues a token with no verification step, login and reset are not rate-limited, and the administrative revoke endpoints are unguarded (SEC-02, SEC-05, SEC-07).

8.2 Gate clearance

21. A clear request on /projects/:projectId/gates/:gateCode is checked for gates:clear by PermissionsGuard.
22. Inside a transaction, the project row is locked (UPDATE lock), then the gate's conditions are evaluated: required documents, drawings, mandatory QC and task executions, payment milestones and the phase-specific rules.
23. If all conditions pass, the gate is marked cleared, the first uncleared gate for the phase is advanced, and a transition record is written in the same transaction. Downstream gates may be relocked on reopen.
24. Completion flags on the project are display caches and are never used as evidence. Command Center cache is invalidated after commit.

Concurrency verification against MySQL is recorded as outstanding in GATE_ENGINE.md. That verification should be scheduled before production use.

8.3 BOQ approval

A BOQ is submitted, then approved through /boqs/:id/approve. The current implementation records the approver from an optional current user and writes null when none is present, and the route is unguarded. The intended flow (submission, approval, client approval through the portal, version duplication on change) is sound once actor identity and permission checks are enforced (SEC-03).

8.4 Client portal

25. A staff user creates a client link through the authenticated client-portal controller. The service generates 24 random bytes, stores a SHA-256 hash for lookup, and stores an AES-256-GCM encrypted copy so the link can be redisplayed.
26. The client opens /public/client/:token. The token is hashed and matched. Expiry, revocation and purpose are checked, and the link's touch timestamp is updated.

27. Client actions (approve BOQ, select quotation, accept handover, raise a snag) are recorded against the link and the project.

The token design is strong. The encryption key derivation is weak (SEC-09), and the public routes have no rate limiting (SEC-07).

8.5 Search

Global search (GET /search) builds an Elasticsearch bool query. It adds a project_id filter unless the caller is an administrator, and it excludes soft-deleted records unless the caller is an administrator who explicitly requests them. The index is populated only by POST /search/reindex/all. Between reindexes, edits, deletions and new records are not visible to search. The permission filter depends on req.user, which the search controller does not guarantee (SEC-04).

8.6 Notifications

Domain services create notification rows, and Sequelize afterCreate and afterUpdate hooks on notification-relevant models fan events out through NotificationBroadcastService to the Socket.IO /notifications namespace. Clients connect with the JWT in the handshake, which is verified with AuthService.getCurrentUser, and join a room keyed by user identifier. Fan-out across instances uses the Redis adapter outside development (ARCH-04).

8.7 Automation

Domain services emit one of five events (QC_FAILED, PAYMENT_MILESTONE_OVERDUE, TASK_OVERDUE, PHASE_STALLED, RFI_OVERDUE) onto the in-process automation bus. The automation engine also evaluates all active rules every AUTOMATION_INTERVAL_MIN minutes. Matching rules run actions such as notifications and escalations, and an audit trail is written. Because the bus is in-process and the timer is local, events are lost on restart and duplicated across replicas (ARCH-01, ARCH-02).

8.8 Command Center cache

The Command Center builds a portfolio aggregate once and shares it across KPIs, portfolios, actions and team workload. Results are fresh for 15 seconds, stale snapshots are served while one background rebuild runs, and Redis entries expire after 120 seconds. Writes to projects, documents, gates, task executions, activity and QC rotate a namespace version. Redis operations are capped at 150 ms, and failures fall back to database computation. Cached data is explicitly not used for authorization or gate decisions. This is a well-designed cache.

9 Security architecture

9.1 Trust boundaries

Boundary	Control today	Assessment
Internet to API	Reverse proxy assumed; no rate limit or Helmet in code	Weak. Add throttling and headers in the application.
Anonymous to authenticated routes	JwtAuthGuard on 47 of 108 controllers	Critical gap. 61 controllers have no guard (SEC-01).
Authenticated to privileged actions	PermissionsGuard on the gates controller only	Critical gap. Roles and permissions are not enforced across the API (SEC-02).
Client (token) to client actions	Opaque token, hashed lookup, expiry, revocation, purpose	Good, apart from key derivation and missing throttling (SEC-09).
Socket.IO clients	JWT verified on connection; per-user room	Good; origin is wildcard (SEC-13).
Public file URLs	UUIDv4 filenames under /cdn	Acceptable for guessing; not acceptable for confidential documents (SEC-11).
Service to database	Single credentials in environment	Unknown grants. Recommend least-privilege roles separated by migration and application.
Service to third parties	OAuth tokens stored in the database	Unencrypted at rest in code (SEC-10).

9.2 Authentication

- Passwords: bcrypt with cost 10. Minimum length 6 in the signup DTO, which is below current guidance (recommend at least 12 characters, with breached-password screening).
- Sessions: 7-day JWT, revocable through auth_tokens. Session records include device and IP fields where supplied.
- Password reset: 32-byte random token, stored as SHA-256 hash, one-hour expiry, single use. Sound.
- OAuth: Google, Microsoft and Zoho sign-in use a state parameter signed with a separate secret and a 10-minute expiry. Sound.
- Signup: issues a session without verification, and is unrestricted (SEC-02).

9.3 Authorization

The RBAC data model is complete: apps (module access), roles, permissions in resource:action form, role-app grants and role-permission grants, with granted_by audit fields. The gates controller applies it through @RequirePermission('gates:...') and PermissionsGuard, with permissions such as gates:read, gates:clear, gates:reopen, gates:override and documents:approve. Everywhere else, the check reduces

to authentication. Object-level checks are limited to search scoping and the gate engine. The reviewed services show no consistent test that the caller belongs to the project being modified.

Consequence. Under the current code, any authenticated account (including one created by open signup) can perform actions reserved to administrators elsewhere in the system, subject only to the frontend's navigation controls. The frontend is not a security boundary.

9.4 Secrets and keys

- JWT_SECRET signs sessions and, through a weak derivation, the client-link key (SEC-09). It is a single point of failure.
- CDN_INTERNAL_SECRET protects the CDN upload endpoint with a shared secret compared directly. Use a constant-time comparison.
- SFTP and Zoho credentials are read from environment variables. Acceptable with a secrets manager. The repository's .dockerignore excludes .env files.
- The seed tooling documents a shared default password (SEC-14).

9.5 Data protection

Response serialisation strips known secret keys at any depth, which is a robust safety net. OAuth refresh tokens and third-party credentials are not encrypted at rest (SEC-10). Personal data includes staff contact details, client contact details and vendor contacts. No retention or deletion workflow was identified in the reviewed code.

9.6 Input handling and injection

Validation is applied through DTOs with class-validator and a whitelisting pipe. Raw SQL is used at 17 call sites. Twelve use bound replacements. The remaining site is static SQL. No request-derived value was found concatenated into SQL in the static review. This is a good result. Uploads are the weaker area (SEC-12).

9.7 Public information and error handling

A global exception filter (http-exception.filter.ts) normalises errors. The system information endpoints disclose runtime details without authentication (SEC-08). Error messages from Sequelize may reveal table and column names in some paths; this should be verified in the exception filter.

10 Data architecture

10.1 Persistence and connectivity

- Database: MySQL, accessed by Sequelize with autoLoadModels enabled and synchronize disabled.
- Connection pool: maximum 5, minimum 0, acquire timeout 30 s, idle 3 s. Retry on connection-lost and refused errors up to three times.
- Database name: hard-coded as spsyn8lm_rippotai_erp in database.config.ts (ARCH-06).
- Timestamps are underscored and enabled by default. Soft delete is opt-in per model.

Capacity note. A pool of five connections is small for a service with 954 handlers, in-process timers and parallel report generation. It may be correct for current load, but it should be justified by measurement and not left at a default.

10.2 Schema management

Schema evolution is by hand. The migrations directory holds 27 SQL files, including a 76 KB checklist template seed and a 21 KB gate-engine migration. Several migration notes say the change has been verified in an in-memory SQLite harness or has not been run against a live database. Those are honest statements, but they mean production MySQL behaviour has not been verified for several recent changes. The application does not record which migrations have been applied (ARCH-07).

10.3 Identifiers

Most entities use UUIDs stored as CHAR(36). Legacy site-operations and process-workflow tables still use integers in places. A migration (20260930_site_ops_project_uuid) moved daily reports and visits to UUID project keys. The residual integer mapping is documented but remains a source of confusion (ARCH-06).

10.4 Concurrency control

Mechanism	Where used	Assessment
Pessimistic row lock in transaction	Gate clear and reopen (projects row)	Correct for its purpose. Verification under MySQL concurrency is outstanding.
Revision counter (optimistic)	Vendor rate comparison sheets	Correct. Prevents lost updates.
Versioning by new rows	BOQ, quotation, budget estimate versions	Good audit trail. Requires care when selecting the current version.
Last write wins	Most other update paths	Acceptable for low-contention records; risky for approvals and shared planners.
Idempotent upserts	Seed scripts (INSERT IGNORE), gate phase seeding	Good for reference data.

10.5 Search data

Elasticsearch holds a denormalised copy of selected entities across 16 indices, with `project_id`, `client_id`, `owner_ids` and `visibility` fields for permission filtering. Its cluster settings are read from `ELASTICSEARCH_NODE` with an unauthenticated localhost default. Production deployments should ensure TLS and authentication on the cluster.

10.6 Caching

Redis holds the Command Center aggregate and the gate-engine coordination state. Caches are namespaced by database and schema version, and expire. The design is documented in `COMMAND-CENTER-CACHE.md` and covered by a dedicated spec.

11 Integration architecture

Integration	Modules	Pattern	Notes and risks
Zoho Bigin CRM	zoho/crm, leads, sync	OAuth 2 authorization code; REST proxy with owner key in path	Owner key is client-supplied (SEC-06). Token refresh is handled in zoho-auth.service.ts.
Zoho Projects	zoho/tasks, sync	REST, task mirroring	Reminder sync polls every 60 s on every instance (ARCH-01).
Zoho Cliq, WorkDrive, Calendar	zoho/cliq, zoho/workdrive, zoho/calendar	REST proxies	All unguarded routes (SEC-01).
Google Calendar and Tasks	google	OAuth 2, tokens in google_tokens	Tokens unencrypted at rest (SEC-10). Guarded.
Microsoft OneDrive and calendar	microsoft	OAuth 2, tokens in microsoft_tokens	Same as Google.
Brevo	common/mail	SDK, transactional email	Sender configuration not reviewed; verify SPF and DKIM for the sending domain.
SFTP CDN	cdn, common	ssh2-sftp-client with password authentication	Password-based SFTP. Prefer key-based authentication.
Local /cdn static directory	main.ts	Express static, CORS wildcard	Public by URL (SEC-11).
Puppeteer and Chromium	boqs (export), documents (pdf-generator)	In-process headless browser	Memory and CPU spikes (ARCH-05). Needs a concurrency limit.
Elasticsearch	search	Official client, bulk indexing service	No write-path sync (ARCH-03).

11.1 Integration design observations

- Integrations are structured as module-local services with their own models and tokens. This is pragmatic, but it means each integration reimplements token refresh, error mapping and retry behaviour.
- External calls generally have no timeout, circuit breaker or retry policy visible in the reviewed code. A slow external API can therefore hold request threads.
- There is no outbound webhook or event contract for other systems. All integration is pull or scheduled.

12 Background processing and real-time

Mechanism	Trigger and behaviour	Scaling behaviour	Recommendation
Automation engine	setInterval, default 30 min; evaluates active rules	Runs on every replica	Durable scheduled job with a lock (ARCH-01)
Reminder sync	setInterval, 60 s; syncs Zoho reminders	Runs on every replica; can double-write Zoho	Single leader or queue (ARCH-01)
Automation bus	In-process EventEmitter with setImmediate	Not shared; lost on restart	Transactional outbox (ARCH-02)
Notification hooks	Sequelize afterCreate and afterUpdate	Per instance; delivery to clients via adapter	Outbox plus queue (ARCH-02)
Socket.IO /notifications	Socket.IO with Redis adapter outside development	Works across replicas only with adapter	Always enable the adapter when multi- instance (ARCH-04)
Command Center refresh	Background rebuild on stale read; one per process	Per-process single-flight plus Redis generation	Acceptable
Startup seeding	Architect seed and lead seed services on module init	Runs on every boot	Gate behind an explicit migration or seed command

The startup seed services (architect-seed, leads, notification events) run on module initialisation. That means every replica runs them on every boot. Their idempotency should be verified, and they should be moved out of application startup where possible.

13 Deployment and operations

13.1 Build and release

28. Push to main that touches backend/** triggers a GitHub Actions workflow (documented in documentation/DEPLOYMENT.md, not included in the archive).
29. The workflow builds the Docker image from backend/ and pushes it to GitHub Container Registry.
30. The workflow connects to the production VPS over SSH and runs docker compose pull and up with --force-recreate inside /opt/apps/rippotai-erp-api.

Gap. The release pipeline runs no tests, no type check and no migration step. A green deploy therefore proves only that the image builds.

13.2 Compose configuration

The repository's docker-compose.yml runs the API with NODE_ENV: development and a Redis service. The production compose described in DEPLOYMENT.md uses NODE_ENV: production and shows no Redis service, although the API depends on Redis for the socket adapter and cache. The two files diverge in ways that matter: development mode disables the Redis socket adapter, enables verbose SQL logging and changes default behaviour (ARCH-04). Compose should be a single source with environment-specific overrides.

13.3 Health and readiness

Endpoint	Behaviour	Problem
GET /api/v1/health/live	Returns static status	Acceptable for liveness.
GET /api/v1/health/ready	Returns 'configured' for database, Redis and Elasticsearch without checking them	Cannot detect dependency failure (ARCH-08).
GET /api/v1/system/info, /system/modules, /system/summary	Runtime and inventory detail	Public (SEC-08).

13.4 Logging and observability

Logging uses the Nest Logger in 40 files and console.log in 18 non-spec locations. No structured log format, request correlation identifier, metrics export or tracing is evident (OPS-01). Incident response would currently rely on reading container logs.

13.5 Backup and recovery

No backup, restore or disaster-recovery procedure is present in the repository. The redis service persists with appendonly yes. The MySQL backup regime is outside the repository and was not reviewed. A recovery point and time objective should be defined and tested.

13.6 Configuration

Twenty-five environment variables are read directly from `process.env` across the code (Appendix B). No startup validation exists (ARCH-09). The single `.env` file pattern is convenient but offers no per-environment separation or audit.

14 Quality engineering

14.1 Build and type checking

A clean install, nest build and the production image's build command all succeed. The compiled output resolves `@/` path aliases correctly. A separate type check of the spec files reports one error (QA-02).

14.2 Automated tests

There are 33 spec files, and the Jest configuration runs those under `src/`. The default npm test command fails to load 29 of 32 suites because the path alias is not mapped (QA-01). With the mapping applied, 30 of 32 suites pass, and 232 of 234 tests pass. The two failures are a stale scaffold test and a gate-evidence mock that does not match the current evaluator. Test coverage is concentrated in the gate engine, shortlist, BOQ, brief, command centre and documents. There is no end-to-end test of any business flow; `test/app.e2e-spec.ts` is the default scaffold.

14.3 Test coverage by risk

Risk area	Covered by tests?	Comment
Authentication and session revocation	Not evident	Highest-risk area without tests.
Route authorization	Not evident	No test enumerates routes against guards. Recommended as a CI gate.
Gate engine evidence and transitions	Yes	Two of the failing tests are here.
BOQ workspace and approval	Partial	<code>boq-workspace.spec.ts</code> exists; whether it asserts the approval actor was not verified in review.
Command Center cache	Yes	Covers reuse, concurrency, background refresh and Redis failure.
Search permission filter	Not evident	Permission behaviour for anonymous callers is untested.
Migrations	Not automated	Verified only by hand (see migration notes).

14.4 Code health indicators

Indicator	Measured value	Target suggestion
Explicit any in non-spec TypeScript	808	Halve within one quarter; forbid in new code via lint
<code>console.log</code> in production code	18	Zero; use Nest Logger
DEBUG logging block in a service constructor	1	Remove

Indicator	Measured value	Target suggestion
TODO comments	5 (including missing guards)	Zero security TODOs; tracked issues for others
Largest service file lines	Procurement services 5,839 across files; projects 4,749; BOQ service 1,581	Split by aggregate (QA-04)
Files referencing integer identifiers	89	Plan migration for legacy tables
Models with soft delete	41	Consistent policy per aggregate

14.5 Documentation quality

The design documents in backend/docs and backend/migrations are candid about verification status, and this is a strength. Each major change (gate engine, unified planner, shortlist packages, vendor rate comparisons) records what was validated, what was not, and how to roll back. The weaknesses are drift in the general architecture documentation (DOC-01) and the absence of a generated route inventory.

15 Non-functional assessment

Quality attribute	Target (suggested)	Current evidence	Assessment
Availability	99.5% monthly for staff operations	Single instance; static readiness; no HA evident	Not assessable; single point of failure
Latency	p95 under 500 ms for list and detail endpoints	Command Center cache; no measurement	Unknown; measure before committing
Throughput	Sized to peak staff concurrency with headroom	Pool of 5; in-process PDF rendering	Likely constrained under concurrent exports
Scalability (horizontal)	Stateless replicas behind a load balancer	Stateful timers; in-process bus; adapter disabled in development	Not ready for multi-replica
Security	Default-deny; least privilege; audited changes	Section 9	Not ready for external exposure
Data integrity	No lost updates on approvals or gates; complete audit	Good on gates and rate sheets; weak on approvals and search	Mixed
Recoverability	Defined RPO and RTO, tested restores	Not in repository	Unknown
Observability	Logs, metrics, traces, alerts	Logs in part; no metrics or traces	Weak
Maintainability	Clear ownership and bounded modules	Consistent structure; large services; drifted docs	Moderate
Testability	Green build meaningful; route and security tests	Default test command broken	Weak
Operability	Validated configuration; safe deployment	Unvalidated config; no migration step in deploy	Weak

The targets in the table are suggestions for discussion rather than existing commitments. They should be agreed with the business before being adopted as acceptance criteria.

16 Findings register

Each finding has an identifier used throughout this document. Severity reflects impact on confidentiality, integrity or availability if the issue is exploited or triggered, weighted by how easily it can be reached. Critical means the issue should be addressed before any further external exposure. Evidence paths are relative to backend/.

Severity	Count
Critical	3
High	8
Medium	15
Low	4

ID	Severity	Area	Finding
SEC-01	Critical	Security	About 60% of route handlers have no authentication guard
SEC-02	Critical	Security	Open self-registration yields an active, fully usable session
SEC-03	Critical	Security / Integrity	BOQ approval can occur without an authenticated actor
SEC-04	High	Security	Search reindex is unauthenticated and anonymous callers see non-project-scoped records
SEC-05	High	Security	Auth lifecycle endpoints are unguarded
SEC-06	High	Security	Zoho CRM proxy routes take the owner key from the URL
SEC-07	High	Security	No rate limiting and no security headers
SEC-08	Medium	Security	System information endpoints are public
SEC-09	Medium	Security	Client-link encryption key is weakly derived and has a hard-coded fallback
SEC-10	Medium	Security	Third-party OAuth tokens are stored without evident encryption
SEC-11	Medium	Security	Uploaded files are publicly addressable
SEC-12	Medium	Security	Upload handling is inconsistent
SEC-13	Low	Security	Socket and HTTP CORS policy is permissive or drifts from documentation
SEC-14	Low	Security	Default demo credentials are documented in the repository
ARCH-01	High	Architecture	Background jobs run in-process with no distributed lock
ARCH-02	High	Architecture	Domain event bus is in-process and not durable
ARCH-03	High	Architecture	Search index is not maintained by write paths

ID	Severity	Area	Finding
ARCH-04	Medium	Architecture	Socket.IO cross-instance fan-out is disabled in development mode
ARCH-05	Medium	Architecture	Single deployable with heavy in-process work
ARCH-06	Medium	Architecture / Data	Environment-specific values are hard-coded and ID schemes are mixed
ARCH-07	Medium	Architecture / Data	Schema evolution is manual and not tracked by the application
ARCH-08	Medium	Operations	Readiness probe does not check dependencies
ARCH-09	Medium	Operations	Configuration is read ad hoc with no startup validation
OPS-01	Medium	Operations	Observability is minimal
OPS-02	Low	Operations	Container runs as root and has no health check
QA-01	High	Quality	Unit test harness fails to load most suites by default
QA-02	Medium	Quality	Test suite is out of sync with production code
QA-03	Medium	Quality	Code quality debt
QA-04	Low	Quality	Several services have grown very large
DOC-01	Medium	Documentation	Architecture documentation is out of date

Table 16.1. Summary of findings. Detail follows.

SEC-01 About 60% of route handlers have no authentication guard

Severity	Critical
Area	Security
Evidence	No global APP_GUARD or middleware. 61 of 108 controllers (576 of 954 handlers) carry no @UseGuards. Examples: src/modules/rbac/roles.controller.ts, src/modules/boqs/boq.controller.ts, src/modules/documents/document.controller.ts, src/modules/zoho/crm/zoho-crm.controller.ts, src/modules/users/team.controller.ts. The team's own documentation/rbac.md lists the Guard column as empty for the RBAC routes.
Recommendation	Add a default-deny global guard with an explicit @Public() allow-list. Add a CI test that enumerates every route and fails on any unclassified route.

SEC-02 Open self-registration yields an active, fully usable session

Severity	Critical
Area	Security
Evidence	POST /auth/signup is unguarded (auth.controller.ts). authService.signup creates an active user with role USER, then returns a JWT in the same response (auth.service.ts). No email verification

	gates this path. PortalAccessGuard, which would block USER, is defined but applied nowhere. Outside the gates module, no role or permission check is applied to guarded routes.
Recommendation	Disable open signup or gate it behind invitation. Require verification before issuing a token. Apply PortalAccessGuard and permission checks globally. Treat authentication alone as insufficient for authorization.

SEC-03 BOQ approval can occur without an authenticated actor

Severity	Critical
Area	Security / Integrity
Evidence	boq.controller.ts approve() takes @CurrentUser() user?: User and passes user?.id. boq.service.ts approve() records approved_by: actorId ?? null. The route is unguarded, so approvals can be recorded with no approver identity.
Recommendation	Require JwtAuthGuard and @RequirePermission('boq:approve') on approve and submit routes. Reject operations where the actor is null. Review existing approval records for null approver values.

SEC-04 Search reindex is unauthenticated and anonymous callers see non-project-scoped records

Severity	High
Area	Security
Evidence	search.controller.ts has no guard. POST /search/reindex/all rebuilds 16 indices. extractUser() reads req.user, which is undefined for anonymous callers, so isAdmin is false and projectIds is empty. global-search.service.ts (lines 275 to 281) then returns only documents without project_id. Clients, staff and vendors carry no project_id, so they may be returned.
Recommendation	Guard the whole controller. Restrict reindex to admins. Derive identity only from the authenticated principal and fail closed when it is absent. Verify the live index contents.

SEC-05 Auth lifecycle endpoints are unguarded

Severity	High
Area	Security
Evidence	auth-tokens.controller.ts exposes GET auth/tokens/user/:userId, PATCH auth/tokens/user/:userId/revoke-all, and DELETE auth/tokens/:id. verification-tokens.controller.ts exposes POST create (caller supplies user_id, token and type) and PATCH consume. No business flow consumes verification tokens in the reviewed code, so the present impact is data integrity and session denial. It is a latent account-takeover path if a consuming flow is added.
Recommendation	Guard or remove these routes. Restrict token administration to admins. Scope revoke-all to the

	caller's own sessions unless an admin.
--	--

SEC-06 Zoho CRM proxy routes take the owner key from the URL

Severity	High
Area	Security
Evidence	zoho-crm.controller.ts routes such as GET and POST :ownerKey/modules/:module and PUT :ownerKey/modules/:module/:id accept the owner key as a path parameter. The routes are unguarded, and the key is not bound to the caller's connected account. The x-owner-key decorator in common/decorator/owner-key.decorator.ts is defined but used nowhere.
Recommendation	Resolve the Zoho account from the authenticated user server-side. Remove client-supplied owner keys from routes.

SEC-07 No rate limiting and no security headers

Severity	High
Area	Security
Evidence	package.json has no @nestjs/throttler, helmet, or equivalent. Login, signup, forgot-password and reset-password are unthrottled. No account lockout is evident in auth.service.ts.
Recommendation	Add throttling on authentication and token endpoints, with lockout or backoff. Add Helmet. Log and alert on repeated failures.

SEC-08 System information endpoints are public

Severity	Medium
Area	Security
Evidence	app.controller.ts routes system/info, system/modules and system/summary are unguarded. They return hostname, Node version, CPU count, environment name, process memory and the module inventory.
Recommendation	Require admin authentication or remove these endpoints from production. Keep only the liveness probe public.

SEC-09 Client-link encryption key is weakly derived and has a hard-coded fallback

Severity	Medium
Area	Security

Evidence	client-portal.service.ts derives its AES-256-GCM key as SHA-256 of 'client-links:' plus JWT_SECRET, falling back to 'inos' when the variable is unset. Rotating JWT_SECRET makes all active client links undecryptable.
Recommendation	Use a dedicated secret with HKDF. Fail startup if it is missing. Decouple it from the session signing key.

SEC-10 Third-party OAuth tokens are stored without evident encryption

Severity	Medium
Area	Security
Evidence	zoho-token.model.ts, google-tokens.model.ts and microsoft_tokens.model.ts store accessToken and refreshToken as TEXT columns. No encryption transform is visible in the model definitions reviewed.
Recommendation	Encrypt refresh tokens at rest with a KMS-managed key. Restrict database access to the service role. Rotate on suspected exposure.

SEC-11 Uploaded files are publicly addressable

Severity	Medium
Area	Security
Evidence	main.ts serves the local CDN directory at /cdn with Access-Control-Allow-Origin: *. Filenames are UUIDv4, which prevents guessing, but any leaked URL grants permanent access to drawings, contracts and signatures.
Recommendation	Serve sensitive documents through authenticated, expiring signed URLs. Keep /cdn for public assets only.

SEC-12 Upload handling is inconsistent

Severity	Medium
Area	Security
Evidence	Several endpoints buffer uploads in memory (multer memoryStorage: cdn, snag-list, daily-site-report, brief). Size limits are set on some and absent on others (only users and brief set explicit limits in the reviewed code).
Recommendation	Set a global body and file size limit. Stream large files to disk or object storage. Enforce MIME and extension checks server-side.

SEC-13 Socket and HTTP CORS policy is permissive or drifts from documentation

Severity	Low
Area	Security
Evidence	notification.gateway.ts sets cors origin '*' (mitigated because the handshake requires a valid JWT). main.ts allowlists six origins while documentation/DEPLOYMENT.md lists four.
Recommendation	Restrict the socket origin list to the same allowlist used for HTTP. Generate the allowlist from one configuration source.

SEC-14 Default demo credentials are documented in the repository

Severity	Low
Area	Security
Evidence	seeds/demo/README.md documents a shared default password for every seeded user, and the seed copies the admin password hash. Safe only if seeding never runs against a shared environment.
Recommendation	Refuse to run the seed unless NODE_ENV is development and a local-only flag is set. Generate per-run random passwords.

ARCH-01 Background jobs run in-process with no distributed lock

Severity	High
Area	Architecture
Evidence	automation-engine.service.ts schedules rule evaluation with setInterval (default AUTOMATION_INTERVAL_MIN = 30). reminder-sync.service.ts polls every 60 seconds with setInterval. Under more than one replica, each instance runs the jobs, producing duplicate notifications and duplicate Zoho writes.
Recommendation	Move scheduled work to a durable queue (for example BullMQ on the existing Redis) with repeatable jobs, or take a Redis lock per job run. Make all job handlers idempotent.

ARCH-02 Domain event bus is in-process and not durable

Severity	High
Area	Architecture
Evidence	common/automation-bus.ts is a Node EventEmitter. Events are emitted with setImmediate and dropped on process restart. Events do not cross instances.
Recommendation	Persist domain events in an outbox table within the same transaction as the state change.

	Dispatch from the outbox to a queue.
--	--------------------------------------

ARCH-03 Search index is not maintained by write paths

Severity	High
Area	Architecture
Evidence	The search module has 16 entity services with reindexAll methods, reachable only through POST /search/reindex/all. No domain service calls an indexing method on write. Sequelize hooks exist only for notifications. The architecture document calls for an outbox and queue, which is not implemented, and package.json has no queue dependency. The index is therefore only as current as the last manual reindex.
Recommendation	Implement the outbox pattern described in backend/docs/search_documentation/SEARCH_SYNC_STRATEGY.md. Index on commit. Keep reindex as a repair tool behind admin authorization.

ARCH-04 Socket.IO cross-instance fan-out is disabled in development mode

Severity	Medium
Area	Architecture
Evidence	main.ts enables the Redis Socket.IO adapter only when NODE_ENV is not development. The repository's docker-compose.yml sets NODE_ENV: development, so a compose-based multi-replica deployment would silently lose cross-instance notifications.
Recommendation	Enable the adapter whenever more than one instance could run. Make the adapter decision explicit configuration, not derived from NODE_ENV.

ARCH-05 Single deployable with heavy in-process work

Severity	Medium
Area	Architecture
Evidence	About 105k lines of TypeScript, 954 handlers and 37 modules run in one process. Headless Chromium (puppeteer) renders PDFs in three files (boq-export, pdf-generator, boq controller) inside the API process. The Sequelize pool is capped at 5 connections (database.config.ts). No concurrency limit on PDF rendering is evident.
Recommendation	Move PDF and Excel generation to a separate worker service. Load-test before changing pool size. Introduce bounded concurrency for rendering.

ARCH-06 Environment-specific values are hard-coded and ID schemes are mixed

Severity	Medium
Area	Architecture / Data
Evidence	database.config.ts hard-codes the database name. Roughly 89 files reference integer or auto-increment identifiers alongside the UUID standard (legacy site-ops and process-workflow tables still use integer mapping per seeds/demo/README.md).
Recommendation	Read the database name from configuration. Record an ID-strategy decision and a migration plan for integer-keyed legacy tables.

ARCH-07 Schema evolution is manual and not tracked by the application

Severity	Medium
Area	Architecture / Data
Evidence	synchronize is false. 27 hand-written SQL files live in migrations/. No migration runner, applied-migration ledger or CI migration test exists in the backend. Documents disagree on the MySQL version (5.7 in GATE_ENGINE.md, 8 in UNIFIED_PROJECT_PLANNER.md). Several migration documents state they have not been run against a live database.
Recommendation	Adopt a migration tool with a version table. Test every migration on a fresh schema and on a copy of production. Record the MySQL version as a platform constraint.

ARCH-08 Readiness probe does not check dependencies

Severity	Medium
Area	Operations
Evidence	app.service.ts getReadiness() returns the literal strings 'configured' for database, redis and elasticsearch without connecting to them. Orchestrators will keep routing traffic to instances whose dependencies are down.
Recommendation	Probe MySQL (SELECT 1), Redis (PING) and Elasticsearch (cluster health) with short timeouts. Return 503 on failure.

ARCH-09 Configuration is read ad hoc with no startup validation

Severity	Medium
Area	Operations
Evidence	25 distinct process.env variables are read across the code, some through ConfigService and many directly. JWT_SECRET is read with a non-null assertion. Nothing validates required variables at startup.

Recommendation	Define one typed configuration schema validated at boot (for example with Joi or zod), and fail fast on missing or malformed values.
-----------------------	--

OPS-01 Observability is minimal

Severity	Medium
Area	Operations
Evidence	Logger is used in 40 files, while 18 console.log calls remain in production code. No metrics endpoint, distributed tracing, structured request logging or error-tracking integration is evident. Only liveness and a static readiness response exist.
Recommendation	Add structured JSON logging with a request identifier, Prometheus-style metrics (request latency, queue depth, pool usage), and error tracking.

OPS-02 Container runs as root and has no health check

Severity	Low
Area	Operations
Evidence	Dockerfile (node:20-alpine) has no USER directive and no HEALTHCHECK. Chromium is installed into the production image.
Recommendation	Run as a non-root user. Add a HEALTHCHECK against /health/live. Consider a separate rendering image.

QA-01 Unit test harness fails to load most suites by default

Severity	High
Area	Quality
Evidence	package.json jest configuration has no moduleNameMapper for the @/ alias. npm test loads 3 of 32 suites and reports 29 'Test suite failed to run'. The documentation works around this with a CLI flag, which is not standard practice.
Recommendation	Add moduleNameMapper using the tsconfig paths to the jest configuration. Make npm test the single supported command.

QA-02 Test suite is out of sync with production code

Severity	Medium
Area	Quality
Evidence	With the mapper applied: 232 of 234 tests pass. app.controller.spec.ts expects 'Hello World!' but

	the controller returns a status object. document-evidence.spec.ts mocks tasks without findAll, which the evaluator now calls. tsc --noEmit fails on gate-engine.spec.ts (expected 9 arguments, got 8). The production build passes because it excludes spec files.
Recommendation	Repair the three tests. Add tsc --noEmit to CI so spec drift is caught.

QA-03 Code quality debt

Severity	Medium
Area	Quality
Evidence	808 explicit 'any' usages in non-spec TypeScript. One DEBUG console block runs in the ProjectDocumentPhaseService constructor. Five TODOs remain, including 'add your AuthGuard / PermissionsGuard' in site-operations visit-stage.controller.ts and snag.controller.ts.
Recommendation	Remove debug output. Resolve the TODO guards as part of SEC-01. Set a target for reducing 'any' in new code, enforced by lint.

QA-04 Several services have grown very large

Severity	Low
Area	Quality
Evidence	Module source totals include material-procurement services at 5,839 lines, projects services at 4,749, boq.service.ts at 1,581 and gate-engine.service.ts at 1,225. These concentrate many responsibilities in single classes.
Recommendation	Split by aggregate: pricing, approvals, export and workflow in BOQ; sub-domains in procurement. Introduce application-layer use cases for cross-module operations.

DOC-01 Architecture documentation is out of date

Severity	Medium
Area	Documentation
Evidence	documentation/ARCHITECTURE.md describes 10 backend modules; the repository has 37. backend/README.md is the unmodified NestJS starter. documentation/DEPLOYMENT.md lists four CORS origins against six in main.ts. The rbac.md route-table reflects the unguarded state without flagging it as a risk.
Recommendation	Make this review the baseline. Assign an owner for backend documentation. Generate the route inventory from code in CI.

17 Architecture decisions (as found)

The repository does not contain formal architecture decision records. The decisions below are inferred from code and design documents. Each should be confirmed by its owner and recorded formally.

ID	Decision	Context and rationale (inferred)	Consequence
AD-01	Modular monolith on NestJS	Single team, tightly coupled domain, speed of delivery	Simple deployment; scaling is coarse; in-process coupling risks
AD-02	MySQL with Sequelize, no automatic schema sync	Existing data and operations; caution with production schema	Manual migrations; drift risk (ARCH-07)
AD-03	JWT sessions with database revocation	Need for logout and revoke-all without a full session store	Every request hits the database; sound design
AD-04	Gate engine as the authority for clearance	Governance of project progression; auditable transitions	Clear source of truth; requires strict use of the engine
AD-05	Pessimistic locks for gate transitions	Prevent concurrent clears and reopens	Correct; contention is limited to a project row
AD-06	Multi-index Elasticsearch for global search	Per-entity mappings and boosting	Requires a sync pipeline that does not yet exist (ARCH-03)
AD-07	Redis for cache and socket fan-out	Shared state across replicas	Adapter conditional on NODE_ENV (ARCH-04)
AD-08	Token-based public client portal	Clients do not need accounts	Good, provided key handling is fixed (SEC-09)
AD-09	In-process automation bus and timers	Simplicity	Not durable and not replica-safe (ARCH-01, ARCH-02)
AD-10	Versioning by new rows for commercial documents	Auditability of BOQs, quotations and estimates	Storage growth; version selection must be correct
AD-11	Puppeteer for PDF rendering in the API	Reuse of HTML templates for exact layouts	Resource contention (ARCH-05)

18 Remediation roadmap

The roadmap is ordered by risk. Phase 0 is a precondition for any external exposure; later phases can overlap once Phase 0 is complete.

Phase 0: contain the exposure (0 to 7 days)

- Confirm open routes in staging with unauthenticated requests. Record the results.
- Review audit, approval and CRM write history for changes made while routes were open. Escalate any unexplained change.
- Add a global default-deny guard with a `@Public()` allow-list. Apply it first to `/rbac`, `/role-permissions`, `/permissions`, `/apps`, `/role-apps`, `/search`, `/auth/tokens`, `/auth/verification-tokens`, `/boqs`, `/zoho/*`, `/documents`, `/team`, `/material-procurement` and the other unguarded controllers listed in Appendix A (SEC-01).
- Disable or gate open signup. Require verification before issuing a session (SEC-02).
- Restrict system endpoints to administrators or remove them from production (SEC-08).
- Add throttling to authentication and token routes, and add Helmet (SEC-07).
- Repair the Jest path mapping and the three out-of-sync tests (QA-01, QA-02).

Phase 1: enforce authorization (within 30 days)

- Define a permission catalogue per module (resource:action). Map every route to a permission. Apply `PermissionsGuard` globally, not per controller.
- Apply `PortalAccessGuard` or its equivalent so `USER` accounts cannot reach staff routes. Remove the dead `x-owner-key` stand-in and bind Zoho calls to the authenticated account (SEC-06).
- Require actor identity on approvals and reject nulls (SEC-03). Add object-level checks that the caller belongs to the project.
- Restrict search reindex to administrators. Derive search identity only from the principal and fail closed (SEC-04).
- Encrypt OAuth refresh tokens at rest. Give the client-link key its own secret with HKDF and fail fast if absent (SEC-09, SEC-10).
- Replace `/cdn` public access for sensitive files with signed, expiring URLs. Enforce size limits globally (SEC-11, SEC-12).
- Validate configuration at startup. Make readiness probe real dependencies (ARCH-08, ARCH-09).
- Run the container as a non-root user and add a health check (OPS-02).

Phase 2: make it operable and scalable (within 90 days)

- Introduce a durable queue (BullMQ on the existing Redis) for automation, reminders, search indexing and notifications. Use repeatable jobs with locks (ARCH-01).
- Implement a transactional outbox for domain events and the search index (ARCH-02, ARCH-03).

- Make the Socket.IO adapter explicit configuration, always on for multi-instance deployments (ARCH-04).
- Move PDF and Excel generation to a worker with bounded concurrency. Load-test to size the connection pool (ARCH-05).
- Adopt a migration tool with a version ledger. Run migrations as a deploy step and test them on a copy of production (ARCH-07).
- Add structured logging, request correlation identifiers, metrics and error tracking (OPS-01).
- Add CI gates: type check, full test run, route-authorization test, dependency audit, and migration test.
- Define backup, restore and recovery objectives, and test a restore (Section 13.5).

Phase 3: evolve the architecture (6 to 12 months)

- Group the 37 modules into bounded contexts with named owners (for example: Commercial, Procurement, Delivery, Documents, Site Operations, Integrations, Identity). Enforce boundaries with lint rules or module-level APIs.
- Extract integrations and document rendering as separate services once the queue and outbox exist.
- Break up the largest services by aggregate and introduce application-layer use cases for cross-module operations (QA-04).
- Standardise on UUID identifiers and retire integer-keyed legacy tables (ARCH-06).
- Build read models for the Command Center and portfolio dashboards so they no longer depend on live aggregation.
- Record architecture decisions formally, starting with those in Section 17.

19 Developer operating guide

19.1 Local setup

31. Install Node.js 20 and MySQL 8 (or the version confirmed for your environment), and Redis 7 if you need the socket adapter or caching.
32. From backend/, run PUPPETEER_SKIP_DOWNLOAD=true npm ci to skip the Chromium download if you have a system Chromium.
33. Create .env with the variables in Appendix B. Keep it out of version control. Set NODE_ENV=development for local work.
34. Apply migrations in migrations/ in filename order, skipping any already applied. Record each one.
35. Start with npm run start:dev.

19.2 Running tests

```
npm test # currently fails to load most suites (QA-01)

# Until QA-01 is fixed, use the documented workaround:
npx jest --passWithNoTests --moduleNameMapper='{ "^@/(.*)$": "<rootDir>/$1" }'
```

```
# Targeted suites documented in migrations/*.md, for example:
node node_modules/jest/bin/jest.js --runInBand --moduleNameMapper '{ "^@/(.*)$": "<rootDir>/$1" }'
gate-engine.spec
```

19.3 Seeding demo data

seeds/demo/run.sh applies pending migrations and then generates and loads demo data for every module. It uses MariaDB and Python 3. The seed is re-runnable and idempotent through INSERT IGNORE. Never run it against a shared environment. The seeded user password is documented in seeds/demo/README.md and must not be reused in any deployed system (SEC-14).

19.4 Adding a feature

- Create a module folder under src/modules with the standard layout, and register it in app.module.ts.
- Declare the guard on every controller, and a @RequirePermission on every handler that mutates data. Do not rely on the frontend for access control.
- Put multi-table writes inside a Sequelize transaction. Use row locks where a state machine must not race.
- Add a migration in migrations/ with a dated name, and a Markdown note describing verification and rollback, following the existing pattern.
- Index new searchable entities through the outbox once it exists. Until then, document the reindex requirement.
- Add a spec for every guard, permission and state transition you introduce.

19.5 Conventions

- Identifiers: UUIDv4 for new tables. Do not add integer keys.
- Money and quantities (recommended convention, not verified in review): use DECIMAL columns and avoid floating-point arithmetic in code paths that persist values.
- Deletion: soft delete with paranoid models for business records. Hard delete only for transient tokens.
- Responses: never return secret columns. The interceptor is a safety net, not a substitute for explicit selection.

20 Assumptions, limitations and glossary

20.1 Assumptions

- The archive reflects the code deployed or intended for deployment on 10 October 2026.
- A reverse proxy in front of the API terminates TLS and forwards the Host and client address headers. Its configuration was not reviewed.
- The database user has the privileges required for the application and no more. This was not verified.
- Environment variables in production are set according to the Appendix B descriptions. Actual values were not reviewed.

20.2 Limitations

- No live requests were made. Findings SEC-01 to SEC-05 are established from source and must be confirmed by request tests before remediation is scoped.
- No load, latency or concurrency measurements were taken. Performance statements are inferences.
- No penetration testing was performed. The security review is a code review.
- Frontend behaviour was not reviewed except where it bears on backend security.

20.3 Glossary

Term	Meaning in this system
Gate	A checkpoint in a project's progression. Clearing it requires evidence. Twelve gates are defined in migration form.
Gate condition	A single evidence requirement for a gate (document approved, drawing reviewed, QC done, payment milestone reached).
Command Center	The portfolio dashboard that aggregates projects, documents, tasks, QC, team load and commercial data.
BOQ	Bill of quantities: itemised scope and cost for a project, versioned and approvable.
L1	Lowest-price vendor in a comparison of quotations for the same scope.
Shortlist package	A saved selection of vendors and materials that can be applied to another project.
Client link	An opaque, expiring token that gives a client access to a specific view or action.
DPR	Daily progress report from site (daily_site_reports).
RFI	Request for information raised on site.
Snag	A defect recorded during site inspection, tracked to closure.
Paranoid model	A Sequelize model using soft delete (deleted_at) instead of physical deletion.

Term	Meaning in this system
Outbox	A table of pending domain events written in the same transaction as the state change, then dispatched to consumers.

Appendix A Controller and route inventory

All 108 controllers, sorted with unguarded controllers first. Handler counts are the number of HTTP method decorators in each controller. Guarded means the file imports and applies JwtAuthGuard or CdnGuard. A file that imports a guard but applies it to only some handlers is counted as guarded here; those cases are covered in the findings.

Route prefix	Handler s	Guard	Source file
(root)	7	None	app.controller.ts
(root)	24	None	src/modules/projects/project-planner.controller.ts
(root)	9	None	src/modules/projects/project-dashboard.controller.ts
:projectId/progress	4	None	src/modules/process-workflow/progress.controller.ts
:projectId/timeline	1	None	src/modules/process-workflow/timeline.controller.ts
activity-logs	3	None	src/modules/engagement/activity-logs.controller.ts
apps	5	None	src/modules/rbac/apps.controller.ts
architect/snags	6	None	src/modules/site-operations/snag.controller.ts
architect/visit-stages	5	None	src/modules/site-operations/visit-stage.controller.ts
auth/tokens	5	None	src/modules/auth/auth-tokens.controller.ts
auth/verification-tokens	4	None	src/modules/auth/verification-tokens.controller.ts
boqs	37	None	src/modules/boqs/boq.controller.ts
budget-estimates	9	None	src/modules/budget-estimate/budget-estimate.controller.ts
delivery-challans	6	None	src/modules/material-procurement/controllers/delivery-challan.controller.ts
document-requirements	6	None	src/modules/documents/document-requirements.controller.ts
document-types	7	None	src/modules/documents/document-types.controller.ts
documents	22	None	src/modules/documents/document.controller.ts
documents	2	None	src/modules/documents/document-register.controller.ts
drawings	9	None	src/modules/documents/drawing.controller.ts
gates	3	None	src/modules/process-workflow/gate.controller.ts
material-procurement	6	None	src/modules/material-procurement/controllers/material-procurement.controller.ts
materials	11	None	src/modules/material-procurement/controllers/material-master.controller.ts

Route prefix	Handlers	Guard	Source file
payment-schedules	10	None	src/modules/payments/payment-schedule.controller.ts
permissions	5	None	src/modules/rbac/permissions.controller.ts
plan-of-actions	8	None	src/modules/plan-of-action/plan-of-actions.controller.ts
procurement/estimates	5	None	src/modules/material-procurement/controllers/material-estimate.controller.ts
procurement/quotations	6	None	src/modules/material-procurement/controllers/material-quotation.controller.ts
procurement/rate-sheets	6	None	src/modules/material-procurement/controllers/material-rate-sheet.controller.ts
procurement/requirements	7	None	src/modules/material-procurement/controllers/material-requirement.controller.ts
procurement/sample-boards	6	None	src/modules/material-procurement/controllers/sample-board.controller.ts
project-shortlists	11	None	src/modules/vendors/project-shortlist.controller.ts
project-types	5	None	src/modules/projects/project-type.controller.ts
projects-phases	5	None	src/modules/projects/project-phase.controller.ts
purchase-orders	7	None	src/modules/material-procurement/controllers/purchase-order.controller.ts
quotations	5	None	src/modules/quotations/quotation-versions.controller.ts
quotations/:quotationId/items	5	None	src/modules/quotations/quotation-items.controller.ts
rbac	6	None	src/modules/rbac/roles.controller.ts
role-apps	6	None	src/modules/rbac/role-apps.controller.ts
role-permissions	5	None	src/modules/rbac/role-permissions.controller.ts
scope-of-work	25	None	src/modules/scope-of-work/scope-of-work.controller.ts
search	21	None	src/modules/search/search.controller.ts
shortlist-entries	7	None	src/modules/vendors/shortlist-entry.controller.ts
site-ops/checklists	10	None	src/modules/site-operations/qc.controller.ts
site-ops/daily-reports	10	None	src/modules/site-operations/daily-site-report.controller.ts
site-ops/mockups	5	None	src/modules/site-operations/mockup.controller.ts
site-ops/rfis	8	None	src/modules/site-operations/rfi.controller.ts
site-ops/visits	11	None	src/modules/site-operations/site-visit.controller.ts

Route prefix	Handler s	Guard	Source file
site-recces	12	None	src/modules/reki/reki.controller.ts
team	31	None	src/modules/users/team.controller.ts
terms-templates	7	None	src/modules/metast/terms.controller.ts
units	5	None	src/modules/metast/units.controller.ts
vendor/business-types	3	None	src/modules/vendors/vendor-business-types.controller.ts
vendor/categories	2	None	src/modules/vendors/vendor-categories.controller.ts
work-orders	8	None	src/modules/material-procurement/controllers/work-orders.controller.ts
workflow	4	None	src/modules/process-workflow/continuity.controller.ts
workflow/library	13	None	src/modules/process-workflow/library.controller.ts
zoho/bigini	37	None	src/modules/zoho/crm/zoho-crm.controller.ts
zoho/calendar	10	None	src/modules/zoho/calendar/zoho-calendar.controller.ts
zoho/cliq	20	None	src/modules/zoho/cliq/zoho-cliq.controller.ts
zoho/projects	25	None	src/modules/zoho/tasks/zoho-tasks.controller.ts
zoho/workdrive	3	None	src/modules/zoho/workdrive/workdrive.controller.ts
(root)	16	Yes	src/modules/client-portal/client-portal.controller.ts
(root)	7	Yes	src/modules/workspace/workspace.controller.ts
architect/quality	7	Yes	src/modules/site-operations/quality.controller.ts
auth	7	Yes	src/modules/auth/auth.controller.ts
auth/google	4	Yes	src/modules/auth/oauth/google-oauth.controller.ts
auth/microsoft	5	Yes	src/modules/auth/oauth/microsoft-oauth.controller.ts
auth/zoho	4	Yes	src/modules/auth/oauth/zoho-oauth.controller.ts
automation	17	Yes	src/modules/automation/automation.controller.ts
boq/activity	1	Yes	src/modules/boqs/boq-activity.controller.ts
boq/templates	11	Yes	src/modules/boqs/boq-template.controller.ts
business-proposals	4	Yes	src/modules/business-proposals/business-proposals.controller.ts
calendar/events	10	Yes	src/modules/calendar/calendar.controller.ts
cdn	1	Yes	src/modules/cdn/cdn.controller.ts

Route prefix	Handler s	Guard	Source file
clients	6	Yes	src/modules/clients/clients.controller.ts
command-center	15	Yes	src/modules/projects/command-center.controller.ts
dashboards	5	Yes	src/modules/dashboard/dashboard.controller.ts
dpr/admin-documents	4	Yes	src/modules/site-operations/admin-dpr-document.controller.ts
dpr/admin-logs	6	Yes	src/modules/site-operations/admin-daily-log.controller.ts
dpr/admin-reports	7	Yes	src/modules/site-operations/admin-daily-report.controller.ts
google/calendar	9	Yes	src/modules/google/google-calendar.controller.ts
google/tasks	11	Yes	src/modules/google/google-tasks.controller.ts
inventory	12	Yes	src/modules/material-procurement/controllers/ inventory.controller.ts
leads	18	Yes	src/modules/leads/leads.controller.ts
library	7	Yes	src/modules/boqs/library.controller.ts
notes	5	Yes	src/modules/workspace/notes.controller.ts
notifications	6	Yes	src/modules/engagement/notifications.controller.ts
onedrive	13	Yes	src/modules/microsoft/microsoft-onedrive.controller.ts
phase-definitions	1	Yes	src/modules/gates/phases.controller.ts
project-briefs	9	Yes	src/modules/brief/brief.controller.ts
projects	5	Yes	src/modules/projects/project-overview.controller.ts
projects	20	Yes	src/modules/projects/projects.controller.ts
projects	2	Yes	src/modules/documents/shared-project-data.module.ts
projects	0	Yes	common/guards/portal-access.guard.ts
projects/:projectId/gates	5	Yes	src/modules/gates/gates.controller.ts
quality-checklists	19	Yes	src/modules/site-operations/quality-checklist.controller.ts
quotations	23	Yes	src/modules/quotations/quotations.controller.ts
reports	5	Yes	src/modules/reports/reports.controller.ts
settings	6	Yes	src/modules/settings/settings.controller.ts
shortlist-packages	5	Yes	src/modules/vendors/shortlist-package.controller.ts
site-ops/snag-lists	6	Yes	src/modules/site-operations/snag-list.controller.ts

Route prefix	Handlers	Guard	Source file
sync	12	Yes	src/modules/sync/sync.controller.ts
tasks	9	Yes	src/modules/tasks/task.controller.ts
user-signatures	3	Yes	src/modules/users/user-signature.controller.ts
users	9	Yes	src/modules/users/users.controller.ts
vendor-rate-comparisons	4	Yes	src/modules/material-procurement/controllers/vendor-rate-comparison.controller.ts
vendors	14	Yes	src/modules/vendors/vendors.controller.ts
vendors/saved-searches	3	Yes	src/modules/vendors/vendor-saved-searches.controller.ts

Table A.1. Totals: 108 controllers; 954 handlers; 61 controllers without a guard, covering 576 handlers.

Appendix B Environment variables

Variable	Purpose
DB_HOST, DB_PORT, DB_USER, DB_PASS	MySQL connection (database name hard-coded in database.config.ts)
JWT_SECRET	Session JWT signing; also used to derive client-link key (SEC-09)
OAuth_STATE_SECRET	Signs OAuth state parameter (10-minute expiry)
PORT, NODE_ENV	HTTP port (default 5000); production enables Redis socket adapter and disables dev logging
REDIS_HOST, REDIS_PORT	Redis for socket adapter, command-centre cache and gate locks
ELASTICSEARCH_NODE, ELASTICSEARCH_USERNAME, ELASTICSEARCH_PASSWORD	Elasticsearch cluster (default http://localhost:9200)
CDN_HOST, CDN_PORT, CDN_USERNAME, CDN_PASSWORD, CDN_UPLOAD_PATH, CDN_BASE_URL	SFTP file store; local /cdn fallback when CDN_HOST is absent
CDN_INTERNAL_SECRET	Shared secret for the CDN upload endpoint (CdnGuard)
ZOHO_CLIENT_ID, ZOHO_CLIENT_SECRET, ZOHO_REDIRECT_URI, ZOHO_ACCOUNTS_URL, ZOHO_DEFAULT_SCOPES	Zoho OAuth
FRONTEND_URL, APP_URL	Links in emails and OAuth redirects
AUTOMATION_INTERVAL_MIN	Automation evaluation interval in minutes (default 30; 0 disables)
APP_VERSION	Reported by system endpoints

Values are not recorded here. Secrets must come from a secrets manager in production.

Appendix C Schema table groups

The schema dump db.sql contains 164 CREATE TABLE statements. The groups below are a working classification for navigation, not a formal ownership map.

Group	Tables
Identity and access	users, teams, team_members, team_sections, team_section_access, roles, permissions, role_permissions, role_apps, apps, auth_tokens, verification_tokens, password_reset_tokens, user_signatures, user_dashboard_layouts
Clients, leads and CRM	clients, leads, lead_activity, lead_notes, lead_tasks, reminder_sync_records, reminder_sync_settings, sync_logs, sync_tasks, sync_calendar_events, zoho_tokens, google_tokens, microsoft_tokens
Projects and gates	projects, project_phases, phases, project_gates, gate_definitions, gate_phase_definitions, gate_conditions, gate_logs, gate_transition_logs, project_types, project_locations, project_scope_categories, project_deliverable_records, project_quality_checks, project_step_progress, steps, step_teams, continuity_roles, milestones
Briefs, recces and scope	project_briefs and 11 project_brief_* child tables, site_recces, site_recce_rooms, site_recce_photos, scope_of_work, scope_categories, scope_items, project_spaces, plan_of_actions, plan_of_action_phases
BOQ, quotations and budgets	boqs, boq_categories, boq_items, boq_miscellaneous, boq_versions, boq_activities, boq_templates, boq_template_categories, boq_template_items, library_categories, library_items, quotations, quotation_items, quotation_versions, quotation_comparisons, budget_estimates, budget_estimate_categories, budget_estimate_items, budget_estimate_miscellaneous, budget_estimate_versions, vendor_rate_comparisons, terms_templates, terms_template_versions
Vendors and procurement	vendors, vendor_categories, vendor_business_types, shortlist_entries, shortlist_packages, project_shortlists, material_masters, material_vendors, material_requirements, material_procurements, material_procurement_items, material_rate_sheets, material_estimates, material_quotations, purchase_orders, purchase_order_items, work_orders, work_order_items, work_order_payment_stages, work_order_terms, delivery_challans, delivery_challan_items, inventory_transactions, sample_boards, project_procurement_items
Payments	payment_schedules, payment_schedule_milestones
Documents and drawings	documents, document_versions, document_types, document_requirements, document_attachments, drawings, drawing_revisions, project_brief_documents, admin_dpr_documents, admin_daily_reports, admin_daily_logs
Site operations	architect_site_visits, architect_visit_stages, visit_assignments, site_visit_logs, daily_site_reports, manpower_entries, rfis, mockups, quality_checklists, quality_checklist_items, quality_checklist_templates, checklist_templates, checklist_template_items, quality_check_heads, qc_sign_offs, qc_sign_off_item_results, snag_lists, snag_items, snag_list_revisions, task_definitions, task_executions

Group	Tables
Planning, tasks and calendar	project_planners, project_planner_items, project_planner_item_locations, planner_task_templates, tasks, calendar_events, notes, deliverables
Engagement, settings and metadata	notifications, activity_logs, settings, units, terms_templates. Automation rule and run storage is not present in db.sql and should be confirmed against the seed definitions (seeds/demo/s09_automation.py).

Appendix D Verification log

Commands and results from the review. The archive can be reproduced with the same commands.

Check	Result
npm ci (PUPPETEER_SKIP_DOWNLOAD=true)	Passed
npm run build (nest build)	Passed; dist/src/main.js produced; no unresolved @/ requires
npx tsc --noEmit -p tsconfig.json	Failed: 1 error in gate-engine.spec.ts (arity 9 vs 8)
npx jest (default configuration)	Failed to load: 29 of 32 suites, no moduleNameMapper
npx jest with moduleNameMapper for @/	2 of 32 suites failed; 232 of 234 tests passed
Static route inventory (regex over controllers)	108 controllers, 954 handlers, 61 controllers without a guard (576 handlers)
Search permission path review	Anonymous request resolves to isAdmin=false, projectId=[]
Raw SQL review (sequelize.query)	17 call sites; 12 use replacements; 1 static; none interpolate request input
Live HTTP probing of endpoints	Not performed: no database or Redis available in review environment

Commands

```
unzip backend.zip && cd backend
PUPPETEER_SKIP_DOWNLOAD=true npm ci
npm run build
npx tsc --noEmit -p tsconfig.json
npx jest --passWithNoTests
npx jest --passWithNoTests --moduleNameMapper='{ "^@/(.*)$": "<rootDir>/$1" }'
```

Route inventory: regex over @Controller and @Get/@Post/@Put/@Patch/@Delete, and @UseGuards presence per file